

Advanced Security and Privacy

Business Continuity Management

Dipl. Ing. Dr. Kevin Theuermann MSc

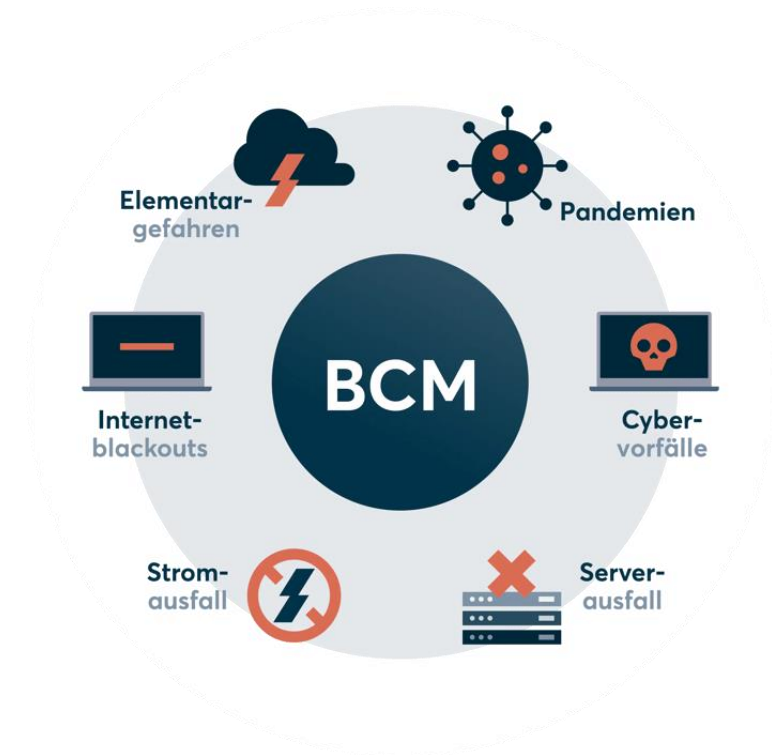
Business Continuity Management

Herausforderungen im Gesundheitswesen:

- ✓ **Kritische Abhängigkeit:** Hochgradige Abhängigkeit von ununterbrochenen Abläufen für die Patientenversorgung und -sicherheit.
- ✓ **Risikoexposition:** Exposition gegenüber Naturkatastrophen, Pandemien, Cyberangriffen und technischen Ausfällen.

Gründe für BCM im Gesundheitswesen

- ✓ **Patientenversorgung:** Gewährleistung der kontinuierlichen und zuverlässigen Versorgung von Patienten in Krisen.
- ✓ **Reputations- und Vertrauensschutz:** Bewahrung des Vertrauens von Patienten und der Öffentlichkeit durch kontinuierliche Qualität und Zuverlässigkeit.
- ✓ **Compliance-Anforderungen:** Einhaltung gesetzlicher Vorschriften und regulatorischer Standards.
- ✓ **Risikomanagement:** Proaktive Minimierung von Risiken, um unerwünschte Auswirkungen auf die Gesundheitsdienste zu vermeiden.



Business Continuity Management

2017 - Cyberangriff auf das britische National Health Service (NHS) :

✓ WannaCry Cyberangriff auf NHS 2017:

- Malware-Angriff traf NHS: Krankenhäuser und Praxen betroffen.
- Absage von Operationen und Schließung von Notfallzentren.
- Einschränkungen in digitaler Bildgebung und Patientenaktenzugriff.

✓ Ursachen und Risiken:

- Veraltete Betriebssysteme und gekürzter Sicherheitssupport aufgrund Finanzierungsmangel.
- Gefährdung der Patientensicherheit bei IT-Angriffen in unterfinanzierten Gesundheitssystemen.

✓ Notwendigkeit neuer Maßnahmen:

- Ärzte betonen Verantwortung für aktuelle Software und Schulungen zu IT-Sicherheit.
- Digitale Medizin hat Vorteile, erfordert jedoch verstärkte IT-Sicherheitsüberlegungen und angemessene Finanzierung.

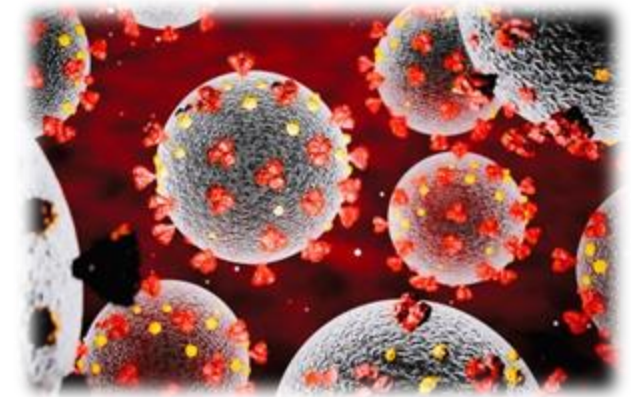


Quelle: [Link](#)

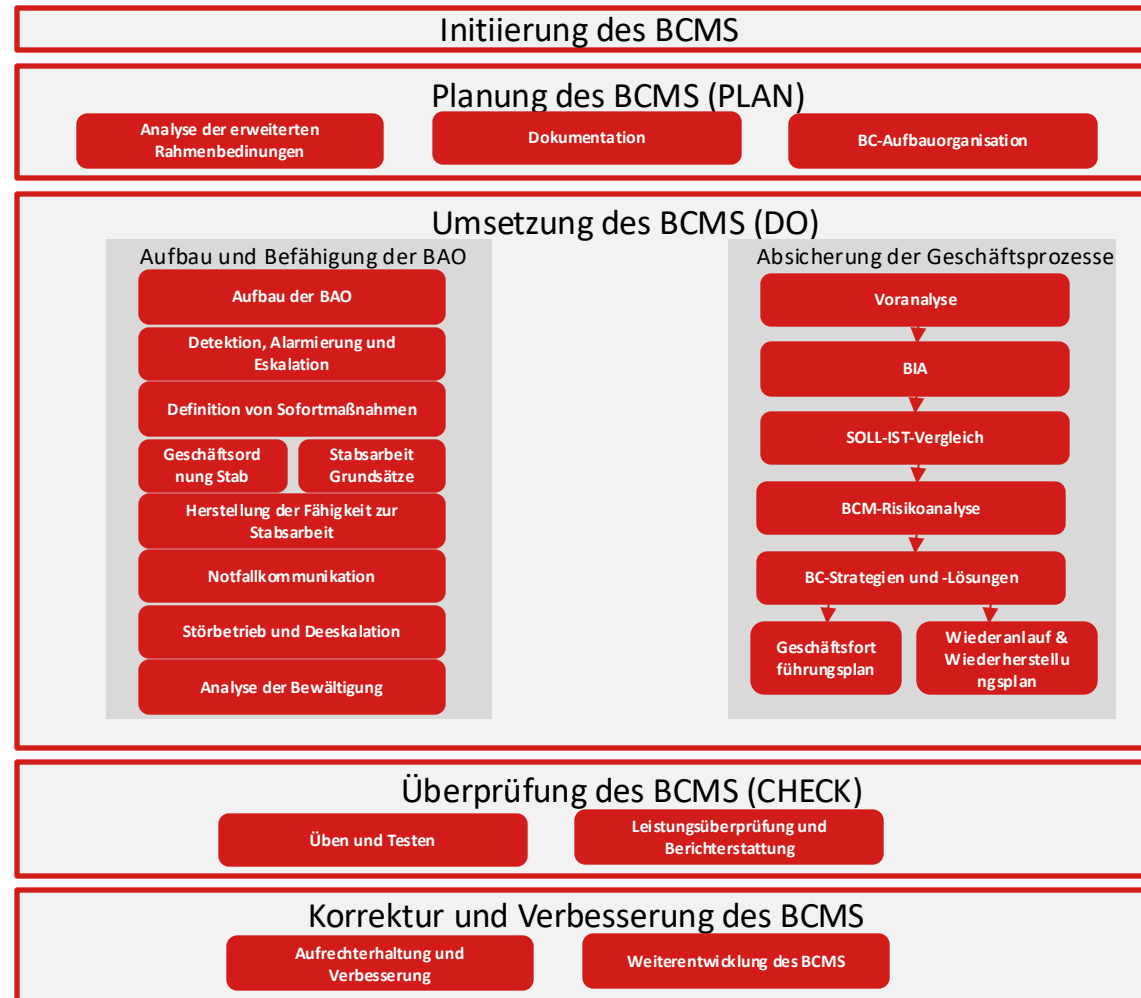
Business Continuity Management

2022 – Covid-19-Pandemie und die Herausforderungen für das Gesundheitswesen:

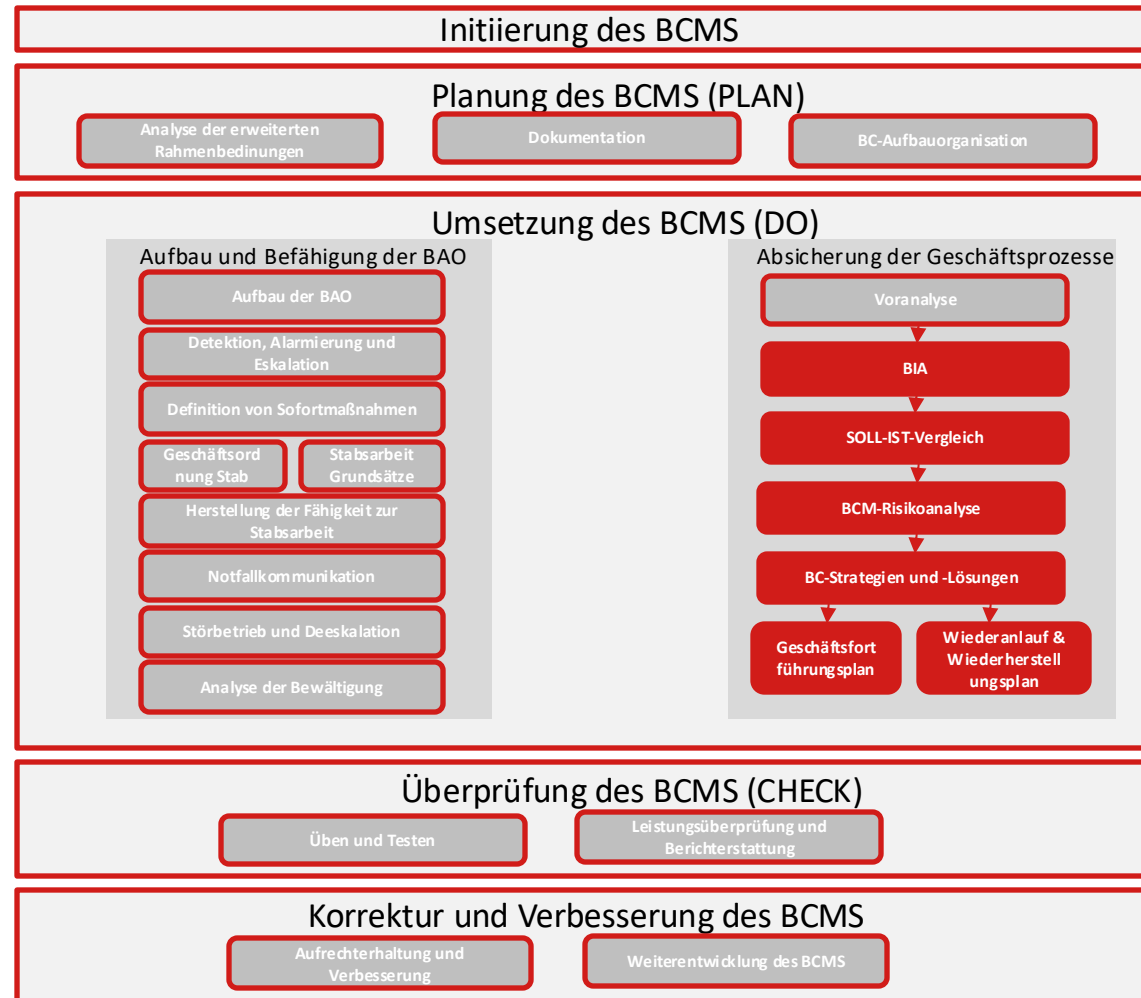
- ✓ Covid-19 Pandemie und Gesundheitswesen:
 - Pandemie stellte das Gesundheitswesen vor enorme Herausforderungen.
 - Belastung der Krankenhäuser durch hohe Patientenzahl und begrenzte Ressourcen.
- ✓ Auswirkungen auf die Gesundheitssysteme:
 - Überlastung der Intensivstationen und Herausforderungen bei der Ressourcenallokation.
 - Notwendigkeit schneller Anpassungen von Gesundheitsrichtlinien und Behandlungsprotokollen.
- ✓ Langfristige Lehren und Veränderungen:
 - Betonung der Bedeutung von Vorsorge, Resilienz und besserer Vorbereitung auf Pandemien.
 - Notwendigkeit von Investitionen in die Gesundheitssysteme und Digitalisierung für Krisensituationen.



Business Continuity Managementsystem



Business Continuity Managementsystem



Business Impact Analyse (BIA)

Ziele der BIA:

- ✓ Identifizierung von zeitkritischen Geschäftsprozessen
 - Wichtige Geschäftsprozesse sind nicht automatisch zeitkritisch
- ✓ Identifizierung von Single-Point-of-Failures
- ✓ Ermittlung der Prozess- und Ressourcenabhängigkeiten im Notbetrieb

Relevante Normen:

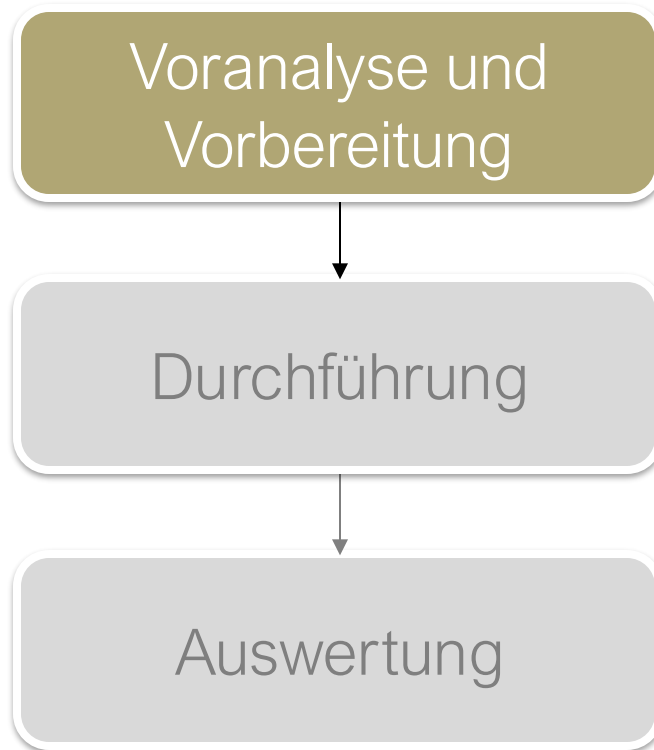
- ✓ BSI 200-4 Business Continuity Management
- ✓ BSI 100-4 Notfallmanagement
- ✓ BSI 100-2 IT-Grundschutz Vorgehensweise



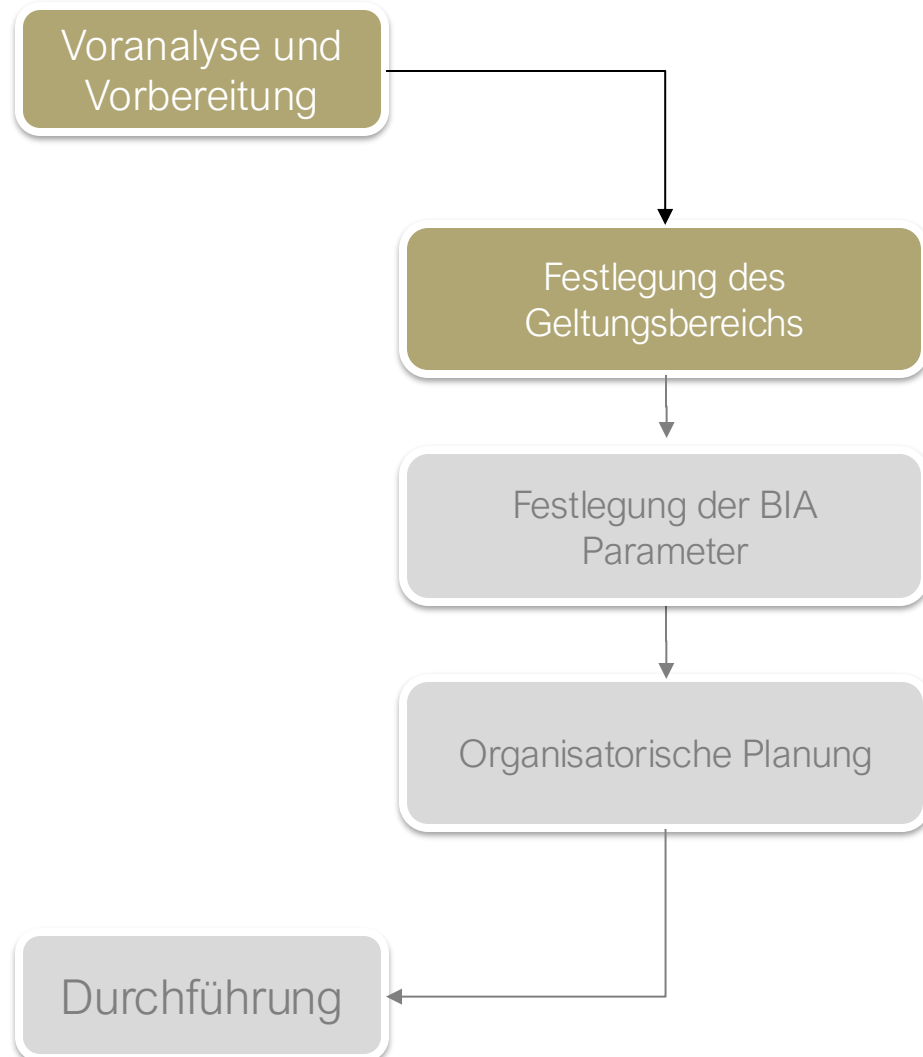
Agenda

- ✓ Business Impact Analyse
 - ✓ Soll-Ist-Vergleich
 - ✓ BCM-Risikoanalyse
-

Business Impact Analyse (BIA)



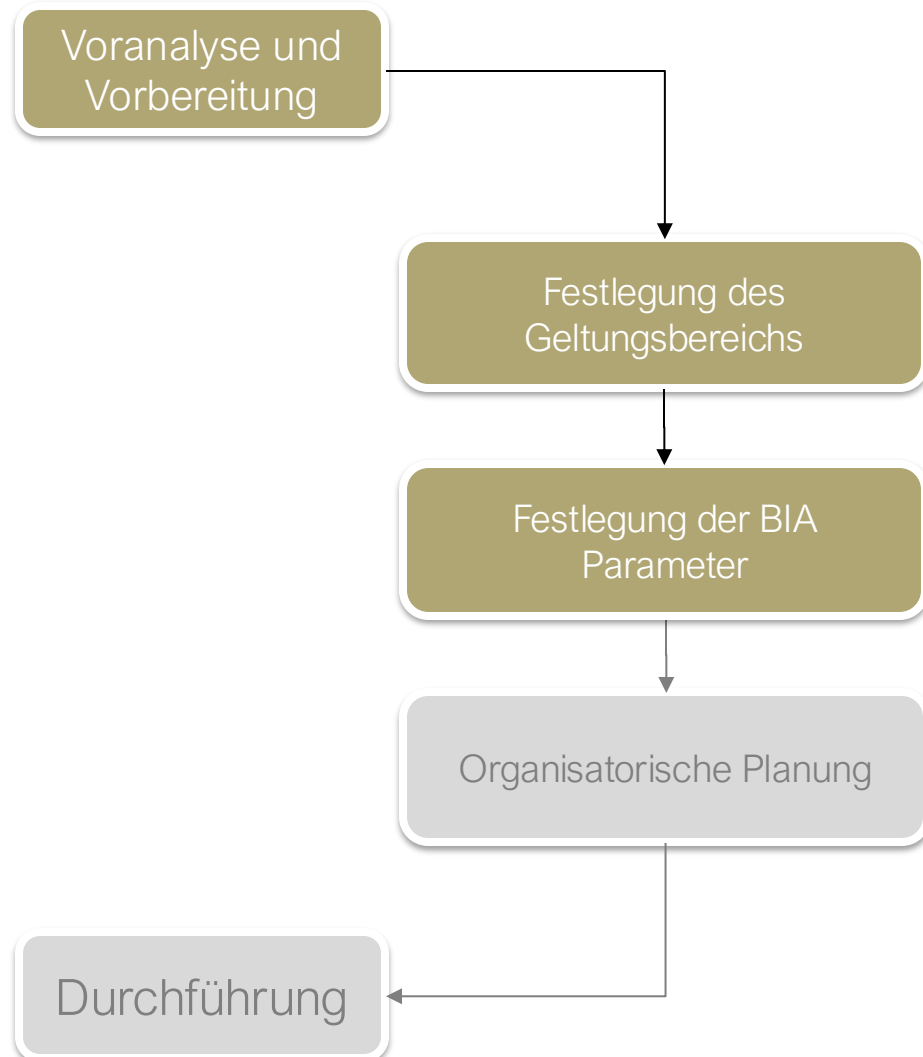
Business Impact Analyse (BIA)



1. Festlegung des Geltungsbereichs:

- ✓ Institutionsleitung legt abzusichernden Bereich fest
- ✓ Umfasst die Gesamtheit von infrastrukturellen, organisatorischen, personellen und technischen Komponenten
- ✓ Festlegung unterschiedlicher Geltungsbereiche ermöglicht Priorisierung in der Erarbeitung (z.B. Betrachtung besonders zeitkritischer Geschäftsprozesse)

Business Impact Analyse (BIA)



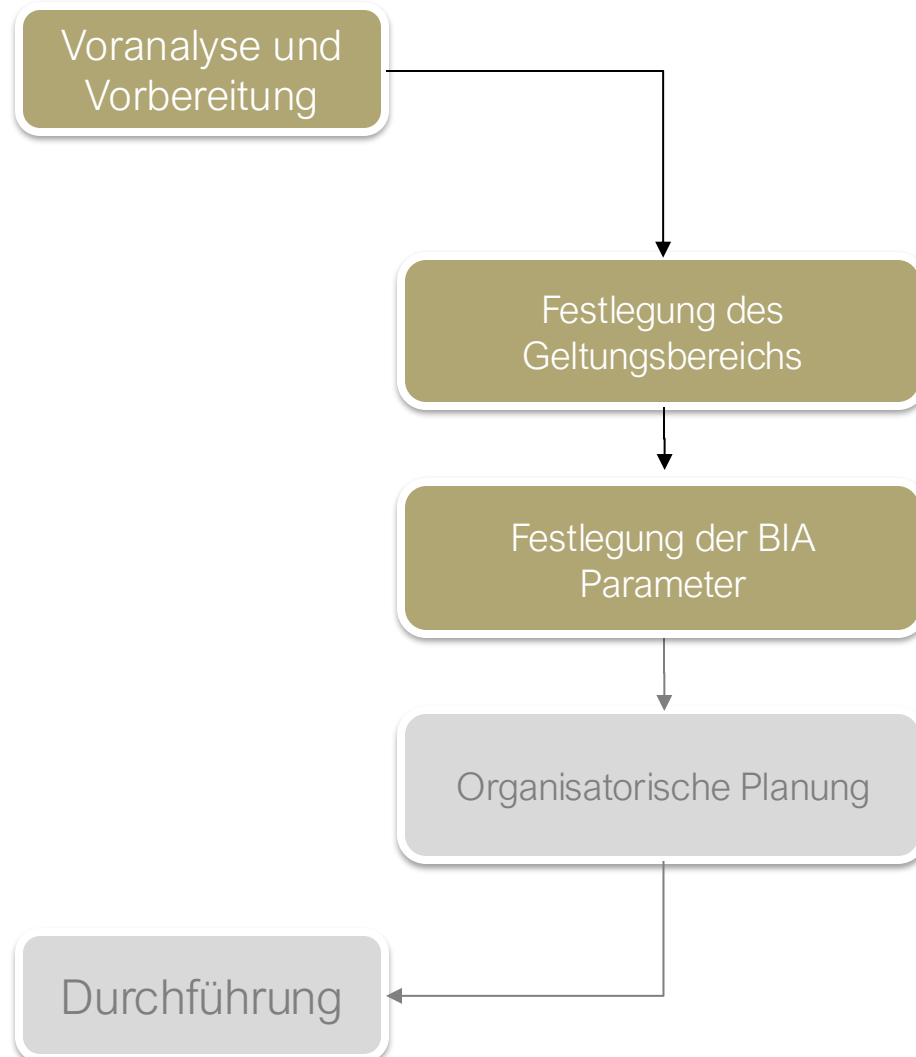
2. Festlegung der BIA-Parameter:

- ✓ Konkretisierung des Begriffs „zeitkritisch“ (Untersuchungszeitraum z.B. 7 Tage, 14 Tage, ...)
- ✓ Definition der Schadenskategorien und -grenze (Untragbarkeitsniveau durch Institutionsleitung)
 - Beeinträchtigung der Aufgabenerfüllung
 - Verstoß gegen Gesetze, Vorschriften, Verträge
 - Negative Innen- und Außenwirkung
 - Finanzielle Auswirkungen
 - Beeinträchtigung der persönlichen Unversertheit

Sind bei einem Ausfall der Geschäftsprozesse dieser Organisationseinheit innerhalb von **7 Tagen zu hohe Schäden für die Institution zu erwarten?**

Untersuchungs-
zeitraum Grenze für das Schadenspotenzial

Business Impact Analyse (BIA)

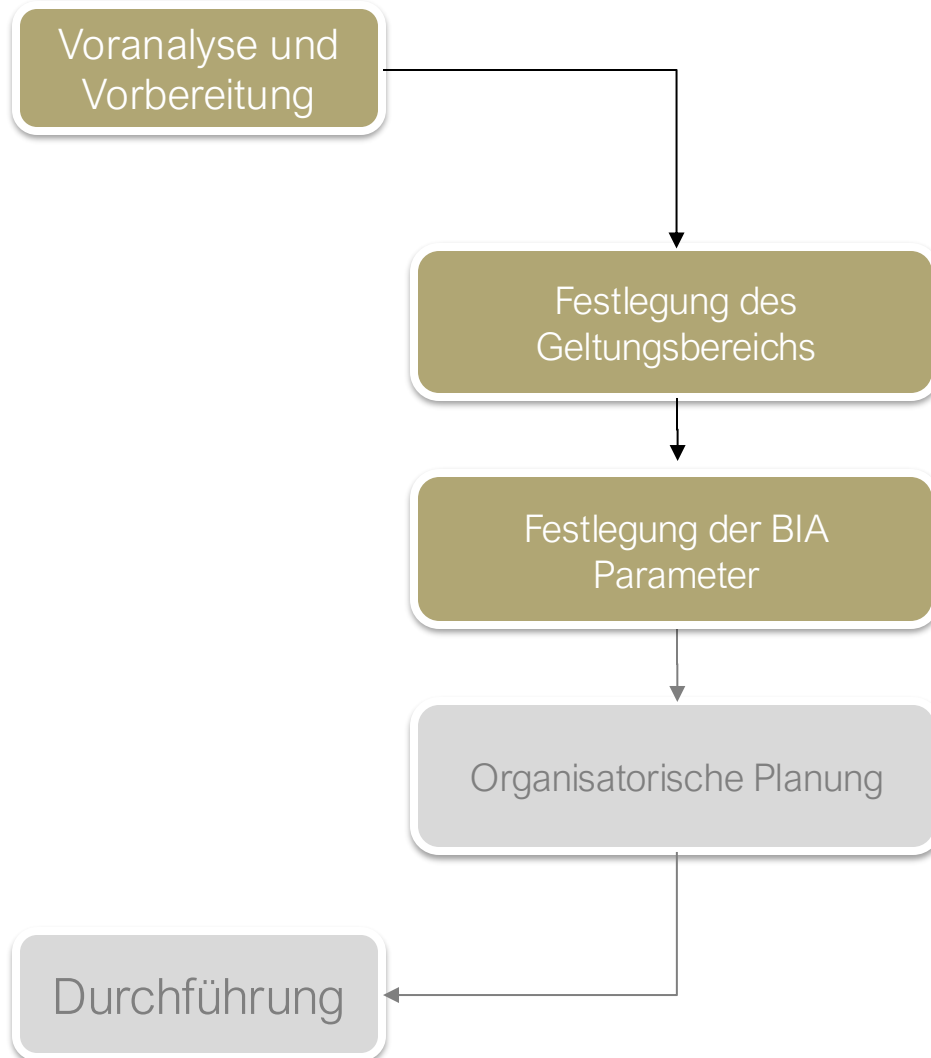


2. Festlegung der BIA-Parameter:

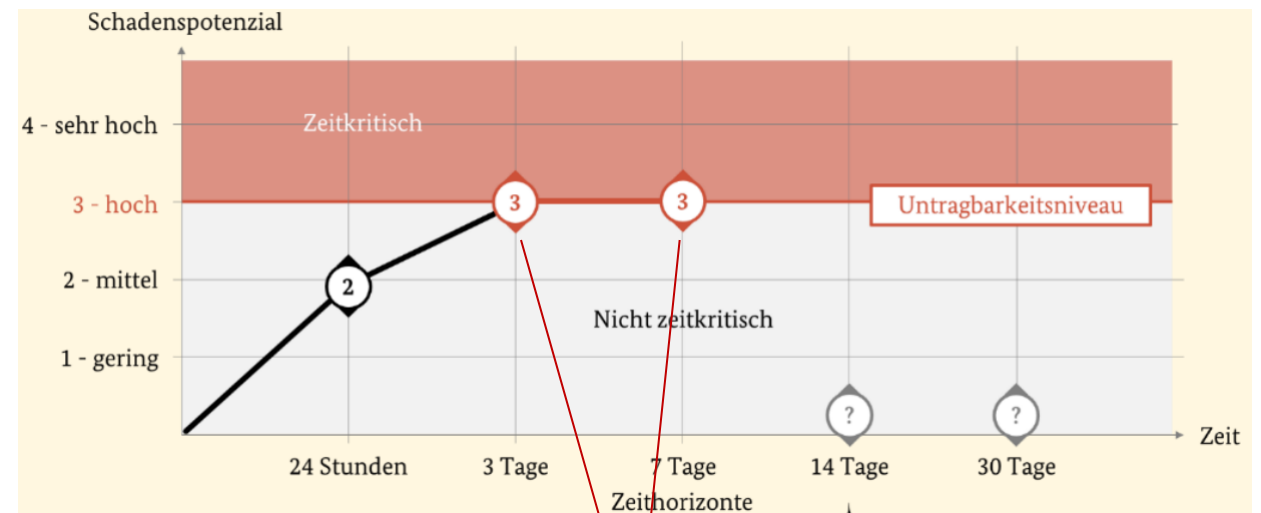
✓ Was ist ein „zu hoher Schaden“?

Schadensszenario	Zu hohes Schadenspotenzial
Beeinträchtigung der Aufgabenerfüllung	Der Geschäftsbetrieb ist massiv eingeschränkt. Arbeitsrückstände sind nur mit erhöhtem Arbeitsaufwand zu kompensieren.
Verstoß gegen Gesetze, Vorschriften und Verträge	Es wird gegen Gesetze verstoßen. Verstöße führen zu erheblichen Konsequenzen, z. B. hohe Bußgelder. Vertragsverletzungen führen zu hohen Konventionalstrafen oder Konsequenzen.
Negative Innen- und Außenwirkung (Imageschaden)	Eine erhebliche, nachhaltige Ansehens- oder Vertrauensbeeinträchtigung ist intern und extern zu erwarten.
Finanzielle Auswirkungen	Der finanzielle Schaden ist für die Institution erheblich und nachhaltig spürbar.
Beeinträchtigung der persönlichen Unversehrtheit	Eine Beeinträchtigung der persönlichen Unversehrtheit kann nicht ausgeschlossen werden.

Business Impact Analyse (BIA)

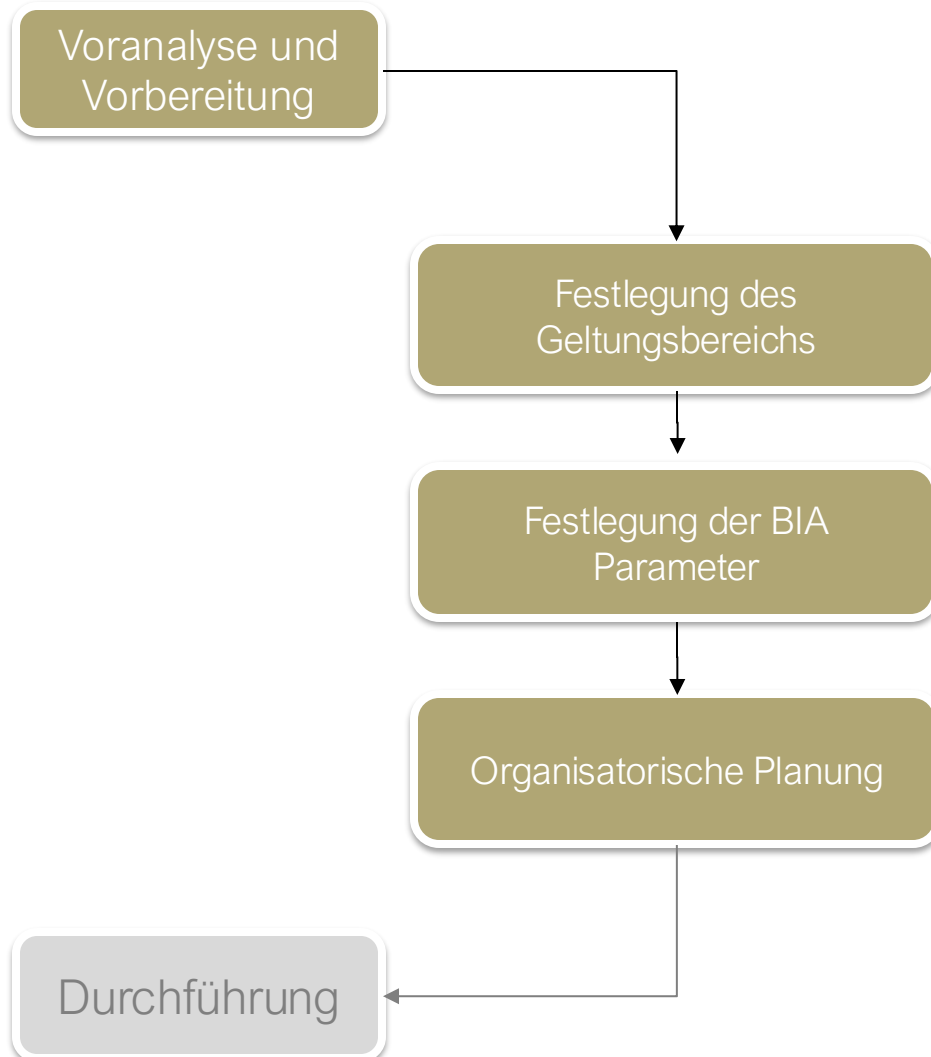


2. Festlegung der BIA-Parameter:



Zeitkritischer Prozess oder zeitkritische Ressource
innerhalb des gewählten Untersuchungszeitraums!

Business Impact Analyse (BIA)

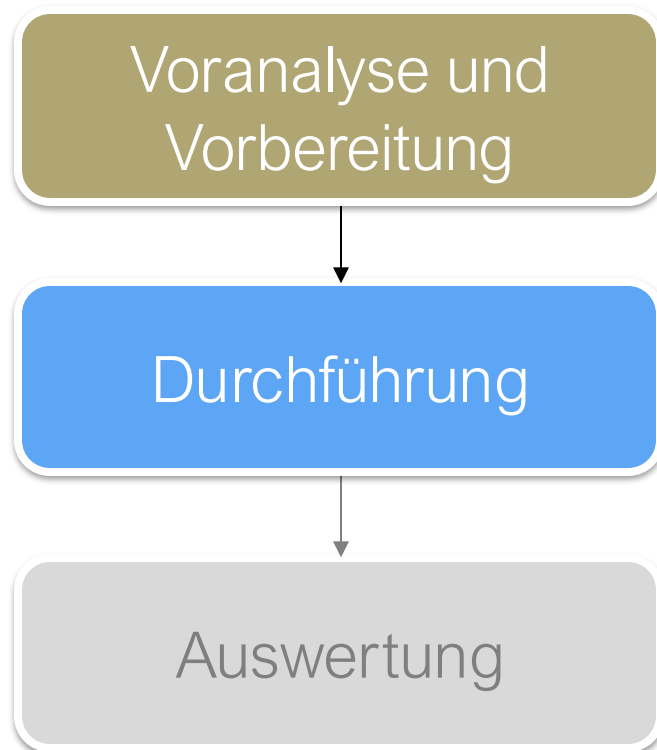


3. Organisatorische Planung

Wie werden Informationen erhoben?

- ✓ Selbstauskunft durch Prozesseigentümer
- ✓ Einzelinterviews mit Personen
- ✓ Workshops mit mehreren Personen

Business Impact Analyse (BIA)



Business Impact Analyse (BIA) - Durchführung

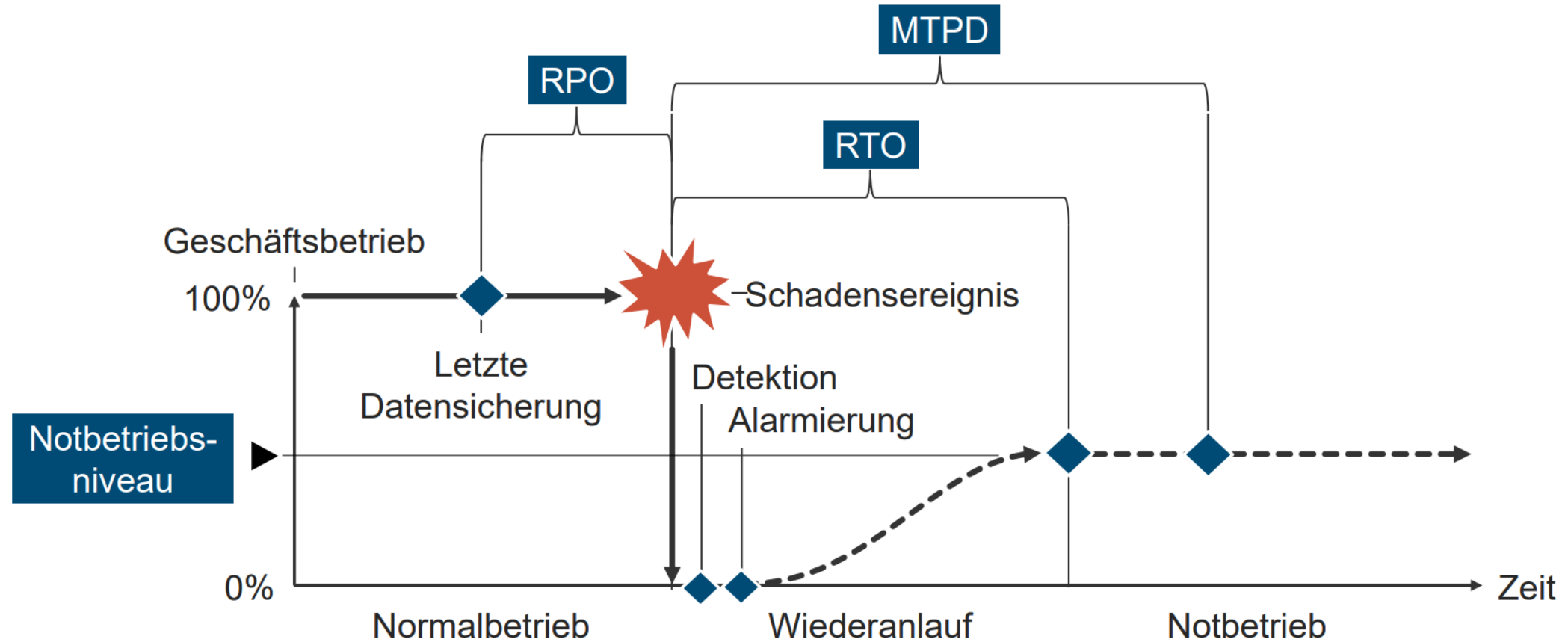
- ✓ Festlegung der Anforderungen für wirtschaftlichen Notbetrieb
- **Maximal tolerierbare Ausfallszeit**
(MTPD = Maximum Tolerable Period of Disruption)
 - **Maximal zulässiger Datenverlust**
(RPO = Recovery Point Objective)
 - **Geforderte Wiederanlaufzeit**
(RTO = Recovery Time Objective)
 - **Notbetriebsniveau**
(MBCO = Minimum Business Continuity Objective)

Beispiel:

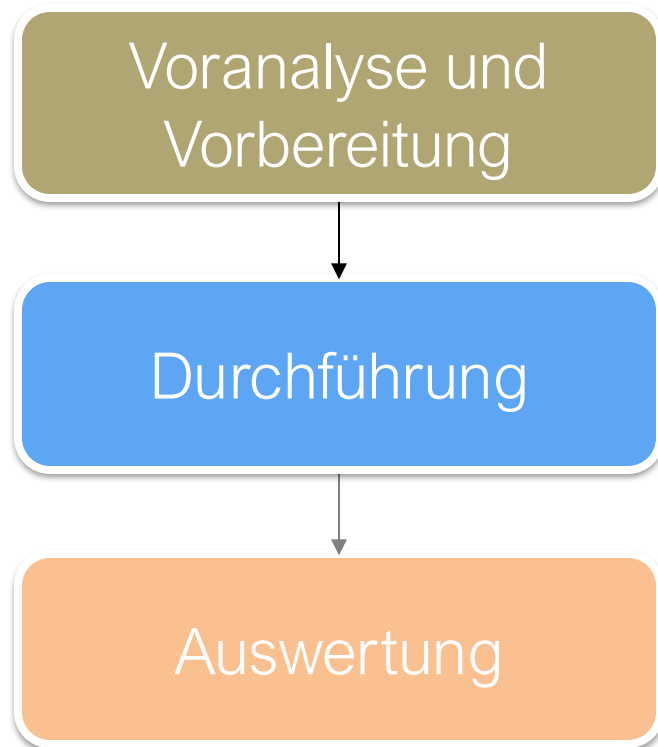
Leitfrage: Wenn der Geschäftsprozess ausfällt, mit welchem Schadenspotenzial [1 (gering), 2 (mittel), 3 (hoch), 4 (sehr hoch)] ist bei einem Ausfall bis zu ... zu rechnen?

Geschäftsprozess	24 Stunden	3 Tage	7 Tage	14 Tage	30 Tage	MTPD
Kundenanfragen bearbeiten	2 (mittel)	3 (hoch)	4 (sehr hoch)	4 (sehr hoch)	4 (sehr hoch)	3 - Tage
Schlüsselkunden betreuen	1 (gering)	2 (mittel)	3 (hoch)	3 (hoch)	3 (hoch)	7 - Tage
Kundenanfragen im Kundencenter entgegennehmen	3 (hoch)	3 (hoch)	3 (hoch)	4 (sehr hoch)	4 (sehr hoch)	24 - Stunden
Kundenzufriedenheitsumfragen	1 (gering)	1 (gering)	1 (gering)	1 (gering)	1 (gering)	Keine

Business Impact Analyse (BIA) – Kenngrößen



Business Impact Analyse (BIA)



Business Impact Analyse (BIA) - Auswertung

Auswertung

Qualitätsgesicherte Zusammenfassung der Ergebnisse:

- ✓ Übersicht der zeitkritischen Geschäftsprozesse und zugehöriger Ansprechpartner
- ✓ Übersicht der Prozessabhängigkeiten
- ✓ Übersicht der abhängigen Ressourcen und SpoFs sowie deren RTO bzw. RPO
- ✓ Mögliche Priorisierung von Ressourcen hinsichtlich geforderter Wiederanlaufzeit

Agenda

- ✓ Business Impact Analyse
 - ✓ Soll-Ist-Vergleich
 - ✓ BCM-Risikoanalyse
-

Soll-Ist-Vergleich

Ziel: Beurteilung, ob die geforderte Wiederanlaufzeit mit vorhandenen technischen und organisatorischen Maßnahmen erreicht werden kann

Relevante Ergebnisse aus der Business-Impact-Analyse:

- ✓ Geforderte Wiederanlaufzeit aller zeitkritischen Ressourcen (**RTO**)
- ✓ Maximal zulässiger Datenverlust (**RPO**)

RTO & RPO sind **SOLL-WERTE**

- ✓ Tatsächliche Wiederanlaufzeit – Recovery Time Actual (**RTA**)
- ✓ Tatsächlicher Datenverlust – Recovery Point Actual (**RPA**)

RTA & RPA sind **IST-WERTE**



Agenda

- ✓ Business Impact Analyse
 - ✓ Soll-Ist-Vergleich
 - ✓ BCM-Risikoanalyse
-

Definition Risiko

✓ ISO 27005:2022

- „effect of uncertainty on objectives“
- Im Kontext von Informationssicherheit bedeutet das: “Information security risks can be expressed as effect of uncertainty on information security objectives”.
- Informationssicherheits-Risiken beziehen sich auf die Ausnutzung von Schwachstellen von Informationswerten

✓ BSI 200-4

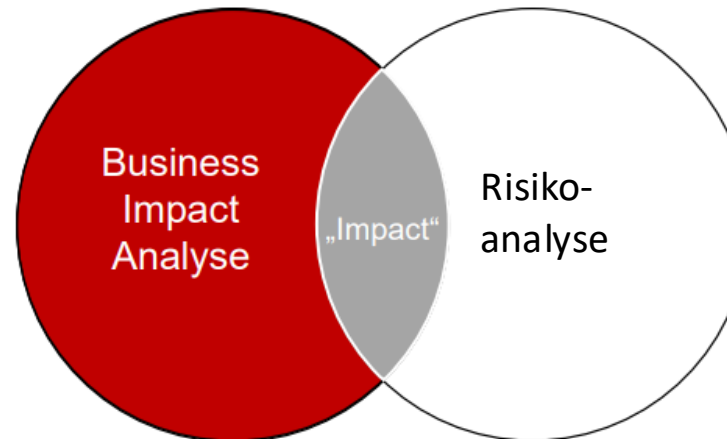
- BCM-Risiken sind Risiken, die sich unmittelbar auf die Verfügbarkeit von zeitkritischen Ressourcen auswirken
 - Aber: Auch Verlust der Integrität einer zeitkritischen Ressource kann zu nicht tolerierbaren Geschäftsunterbrechungen führen
-

BCM Risikoanalyse

Gegenüberstellung Business Impact Analyse (BIA) und Risikoanalyse:

- ✓ Ziel der **BIA**: Was muss abgesichert werden?
- ✓ Ziel der **Risikoanalyse**: Wogegen muss abgesichert werden?

- ✓ Ressourcen- oder Prozessbezogen
- ✓ Wirkungsorientiert
- ✓ Blendet vorhandene Maßnahmen aus (worst case)
- ✓ Ergebnis: Zeitwert (MTPD, RTO, RPO)



- ✓ Ressourcenbezogen
- ✓ Ursachenorientiert
- ✓ Berücksichtigt vorhandene Risiko-reduzierende Maßnahmen
- ✓ Ergebnis: Risikowert

Advanced Security and Privacy

Business Continuity Management

Dipl. Ing. Dr. Kevin Theuermann MSc